

V0088

Advanced Information Security

高级信息安全

Instructor: **Prof. Xiaohong Yu**

Graduate School of Information and Communication Technology,
Ajou University, Korea

访问控制

- 访问控制分为两部分.....
- **身份验证**：你真的是你所声称的那个人吗？
 - 确定是否允许访问
 - 对人机进行身份验证
 - 或者，也可能是机器对机器
- **授权**：您有权这样做吗？
 - 一旦获得访问权限，你能做什么？
 - 强制限制行为
- 注：“访问控制”通常用作授权的同义词。

你真的是你所说的那个人吗?

- 机器如何验证一个人的身份?
- 可以基于.....
 - 你**知道的**
 - 例如, 密码
 - 你**拥有的东西**
 - 例如, 智能卡
 - 你**是谁**
 - 例如, 你的指纹

你知道的事

- 密码
- 很多东西都可以充当密码!
 - 个人识别码
 - 社会安全号码
 - 母亲的姓氏
 - 出生日期
 - 宠物的名字等等。

密码问题

- 密码是当今安全工程师面临的最大实际问题之一。
- 人类无法安全地存储高质量的加密密钥，而且在执行加密操作时速度和准确性都无法接受。

为什么需要密码?

- 为什么“你所知道的”比“你所拥有的”和“你是谁”更受欢迎?
- **费用**: 密码免费
- **便利性**: 对系统管理员来说, 重置密码比发放新证书指纹更方便。

密钥与密码

• 加密密钥

- 密钥为64位
- 然后是 2^{64} 个可能的情况
- 随机选择一种密钥.....
-那么攻击者必须尝试大约 2^{63} 个密钥

• 密码

- SPSE密码为8个字符，最多可包含256个不同的字符。
- 那么 $256^8 = 2^{64}$ 可能的情况
- 用户并非随机选择密码。
- 攻击者拥有的数量远少于 2^{63} 个要尝试的密码 (**字典攻击**)

好的密码和坏的密码

- 错误的密码

- frank
- Fido
- Password
- incorrect
- Pikachu
- 102560
- AustinStamp

- 好的密码?

- jflej,43j-EmmL+y
- 09864376537263
- P0kem0N
- FSa7Yago
- 0nceuP0nAt1m8
- PokeGCTall150

密码实验

- 三组用户：每组用户都被建议按如下方式选择密码

- **A组**：至少6个字符，1个非字母字符

获胜者→ **B组**：基于口令的密码

- **C组**：8个随机字符

- 结果

- **A组**：约30%的密码容易破解

- **B组**：约10%被破解

- 容易记住的密码

- **C组**：约10%被破解

- 难以记住的密码

密码实验

- 用户合规性难以实现
- 在每种情况下，都有三分之一的人不遵守规定。
 - 其中约有三分之一很容易破解！
- 分配密码有时是最好的
- 如果未设置密码，最好的建议是.....
 - 根据口令选择密码
 - 使用密码破解工具测试弱密码
- 需要定期更改密码吗？

密码攻击

- 攻击者可能.....
 - 针对某个特定账户
 - 瞄准系统上的任何帐户
 - 针对任何系统上的任何帐户
 - 尝试发起拒绝服务 (DoS) 攻击
- 常见攻击路径
 - 外部用户→普通用户→管理员
 - 可能只需要一个弱密码!

密码重试

- 假设系统在三次密码错误后锁定。那么应该锁定多长时间?
 - 5秒
 - 5分钟
 - 直到系统管理员手动恢复服务
- 每种方案的优点和缺点是什么?
- **安全性 vs 可用性之间的权衡**
 - 锁得越久 → 更安全，但用户更痛苦
 - 锁得越短 → 用户体验好，但更容易被攻击

密码文件?

- 将密码直接存储在文件中? 不安全
- 但我们需要验证密码
- 解决方案? **哈希**密码
 - 存储 $y = \text{hash}(\text{密码})$
 - 可以通过哈希算法验证输入的密码。
 - 如果攻击者获得了密码文件, 并不会 (直接) 获得密码。
- 但攻击者可以尝试 *向前搜索*。
 - 猜测 x 的值, 并检查 y 是否等于 $h(x)$ 。

字典攻击

- 攻击者预先计算 $h(x)$ ，其中 x 是常用密码字典中的所有元素。
- 假设攻击者获得了包含哈希密码的密码文件访问权限
 - 她只需要将哈希值与预先计算好的字典进行比较即可。
 - 只需一次性计算字典中的哈希值，实际攻击就非常简单了。
- 我们能否阻止这种前向搜索攻击？或者至少增加其攻击难度？

哈希密码和盐 (Hash password with salt)

- 对密码进行加盐后再计算哈希值
- 选择随机数作为盐值s, 并计算

$$y = \text{hash}(\text{password}, s)$$

并将(s, y)存储在密码文件中

- 注意, Salt 值不是秘密的。
 - 与案例IV 类似
- 验证加盐密码仍然很容易
- 但攻击者来说, 需要更多的工作量了。
 - 为什么?

密码破解：数学计算

- 假设：
- 密码为 8 个字符，每个字符有 128 种选择。
 - 那么有 $128^8 = 2^{56}$ ，共有 2^{56} 种可能的密码。
- 有一个**密码文件**有 2^{10} 密码
- 攻击者拥有包含 2^{20} 个常用密码的字典
- **可能**密码中有四分之一在字典里。
- **工作量**以哈希值的数量来衡量。

密码破解： 案例一

- 攻击一个特定密码，不使用字典
 - 例如， 管理员密码
 - 必须平均尝试 $2^{56} / 2 = 2^{55}$ 种可能才能找到密码
 - 类似穷举密钥搜索
- **密钥加盐然后哈希计算** 在这种情况下有用吗？

密码破解： 案例二

- 使用字典攻击一个特定密码

- 加盐

- 预期工作量： $1/4 (2^{19}) + 3/4 (2^{55}) \approx 2^{54.6}$
 - 实际上，要尝试字典中的所有密码.....
 - 那么，工作量最多为 2^{20} ，成功概率为 $1/4$ 。

- 如果**不加盐**呢？

- 一次性计算字典的工作量： 2^{20}
 - 预期工作量与上述相同。
 - 但是，使用预先计算好的字典哈希值，实际上攻击几乎是没有任何工作量的，直接查表就完成了。

密码破解：案例三

- 文件中1024个密码中的任意一个密码，不用字典
 - 假设所有 2^{10} 个密码都是不同的
 - 在找到密码之前需要进行 2^{55} 比较。
- 如果不使用盐
 - 每个计算出的哈希值会产生 2^{10} 次比较。
 - 因此，预期工作量（哈希值）为 $2^{55}/2^{10} = 2^{45}$
- 如果使用盐
 - 预计工作量为 2^{55}
 - 每次比较都需要进行哈希计算。

密码破解：案例四

- 文件中1024个密码中的任意一个密码，使用字典
 - 字典中可能存在一个或多个密码： $1 - (3/4)^{1024} \approx 1$
 - 因此，我们忽略字典中不存在密码的情况。
- 如果使用**盐值，预计**工作量小于 2^{22}
 - 请参阅书籍或幻灯片笔记。
 - 工作量 $\approx$ 字典大小/ P (字典中密码的数量)
- 如果**不放盐**呢？
 - 如果字典哈希值未预计算，则工作量约为 $2^{19}/2^{10} = 2^9$ 。

其他密码问题

- 密码太多，记不住。
 - 导致密码重复使用
 - 为什么这会是个问题？
- 谁会因为密码不好而受害？
 - 登录密码与ATM密码
- 未更改默认初始密码
- 社会工程
- 错误日志可能包含“几乎”正确的密码
- 漏洞、键盘记录、间谍软件等等。

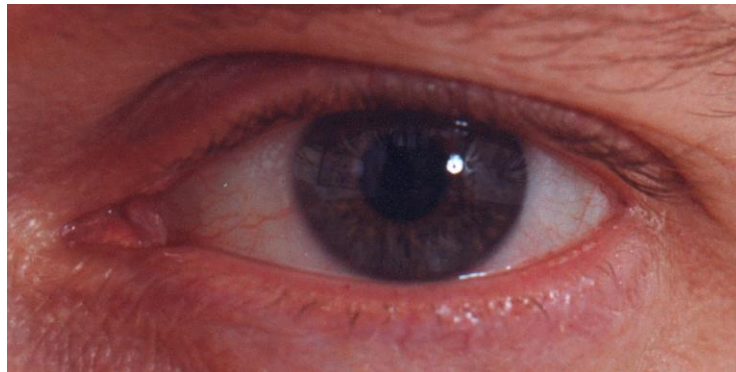
密码

- 归根结底.....
- **密码攻击太容易了。**
 - 通常情况下，一个弱密码就足以破坏安全。
 - 用户选择弱密码
 - 社会工程攻击等。
- 攻击者几乎拥有所有优势
- 所有数学计算都对坏人有利
- 密码是一个**很大的**安全问题。
 - 而且这仍将是一个问题。

密码破解工具

- 常用的密码破解工具
 - [Password Crackers](#)
 - [Password Portal](#)
 - [L0phtCrack and LC4](#) (Windows)
 - [John the Ripper](#) (Unix)
- 管理员应该使用这些工具来测试弱密码，因为攻击者会.....
- 关于密码破解的好文章
 - [Passwords - Conerstone of Computer Security](#)
 - [Passwords revealed by sweet deal](#)

生物识别技术



生物特征

- 生物识别

- “你就是你的密钥” —— Schneier

- 示例

- 指纹
 - 手写签名
 - 面部识别
 - 语音识别
 - 步态（行走）识别
 - “数字狗狗”（气味识别）
 - 还有更多！



为什么选择生物识别技术？

- 比密码更好
- 但是，我们需要廉价且可靠的生物识别技术。
 - 如今，这是一个活跃的研究领域。
- 生物识别技术如今已应用于安全领域。
 - 指纹鼠标
 - 掌纹安全门禁
 - 指纹解锁车门等。
- 生物识别技术现在越来越普及。

理想生物特征

- **通用性**——适用于（几乎）所有人
 - 事实上，没有哪项生物识别技术适用于所有人。
- **区分性**——能够确定地区分
 - 实际上，不可能有百分之百的确定性。
- **持久性** 所测量的物理特性始终保持不变
 - 实际上，如果它能长期保持有效，那就没问题。
- **可采集性** 易于收集所需数据
 - 取决于受试者是否合作。
- 此外，它具有可靠性，鲁棒性，易用性.....

身份识别与认证

- **身份识别** 谁在那里？
 - 比较**一对多**关系
 - 例如： FBI指纹数据库
- **验证** ——你真的是你自称的那个人吗？
 - **一对一**
 - 例如： 指纹鼠标
- 识别问题更加困难。
 - 由于比较次数增多， 因此匹配结果也更加“随机”。
- 我们（主要）对身份验证感兴趣。

注册与认证

- 注册录入阶段

- 受试者的生物特征信息被录入数据库
- 必须仔细测量所需信息
- 如果需要缓慢且重复的测量，则可行。
- 必须非常精确
- 在实际使用中可能是一个弱点。

- 再识别阶段

- 生物特征检测在实践中的应用
- 必须快速简便
- 但必须相当合理准确。

用户配合度

- 认证 —— 用户配合
- 识别 —— 用户不配合
- 例如，面部识别
 - 拉斯维加斯赌场利用这种技术来检测已知的作弊者（也用于机场等地检测恐怖分子）。
 - 没有理想的认证情况。
 - 受试者会试图混淆识别阶段
- 用户配合让学习变得容易得多。
 - 我们专注于身份验证
 - 因此，我们可以假设受试者是合作的。

生物识别错误

- **误判率与拒判率**

- **误判**——攻击者被系统误认为是Alice。
- **拒判**——系统拒绝认证Alice本人是Alice。

- 对任何生物识别系统来说：

- 降低一种错误，就会增加另一种错误

- 例如

- 99% 的声纹匹配度 $\Rightarrow$ 低误判率，高拒判率
- 30% 的声纹匹配率 $\Rightarrow$ 高误判率，低拒判率

- **相等错误率 (EER) :** 误判率和拒判率相同的概率。

- 用来比较不同生物识别系统的好坏

指纹历史

- 1798年——J.C.Mayer 指出指纹特征是独一无二的
- 1823年——约翰内斯·埃万杰利斯特·普尔金耶教授讨论了9种指纹模式
- 1858年——威廉·赫歇尔爵士在印度将指纹用于合同。
- 1880年——亨利·福尔兹博士在《自然》杂志上发表了一篇关于指纹身份识别的文章。
- 1883年——马克·吐温的《密西西比河上的生活》(通过指纹识别凶手)

指纹历史

- 1892年——弗朗西斯·高尔顿爵士建立了分类系统
 - 他提出的“细节”体系在今天仍然适用。
 - 同时验证了指纹不会改变。
- 在刑事案件中匹配固定数量的“要点”（细节）。
 - 在英国，至少有15个点
 - 在美国，没有固定数量的点。

指纹比对

- 环状、涡纹、拱形
- 从这些特征中提取的细节信息



环状（双）



涡纹



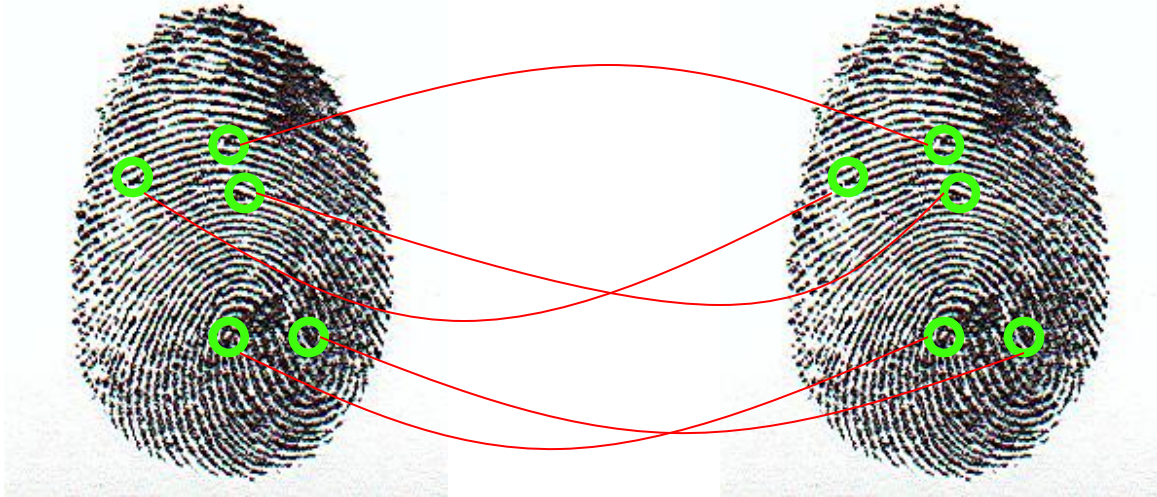
拱形

指纹：登记



- 采集指纹图像
- 增强图像
- 找出“要点”

指纹识别



- 将提取出的点与数据库中存储的信息进行比较。
- 统计数据是否相符？
- 题外话： 同卵双胞胎的指纹会有区别吗？

手掌几何图形

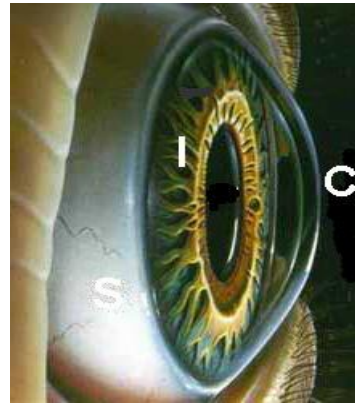
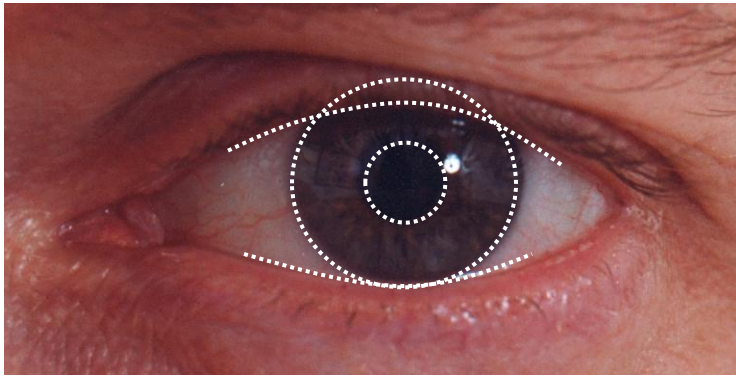
- ❑ 一种流行的生物识别技术
- ❑ 测量手的形状
 - 手掌宽度, 手指
 - 手指长度等。
- ❑ 人手并非那么独特
- ❑ 手部几何形状足以应对许多情况
- ❑ 身份验证通过
- ❑ 不适用于鉴定, 会导致错误匹配



手掌几何图形

- 优势
 - 快速—注册只需1分钟，识别只需5秒
 - 手是对称的——那又怎样？
- 缺点
 - 不可用于幼儿或老年人
 - 相对较高的等错误率

虹膜图案



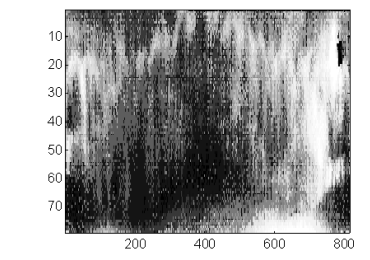
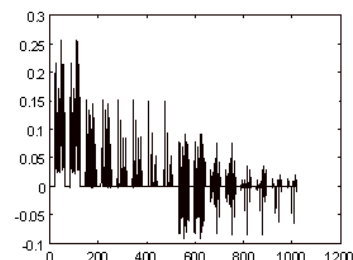
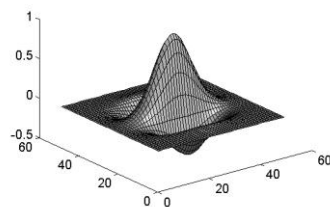
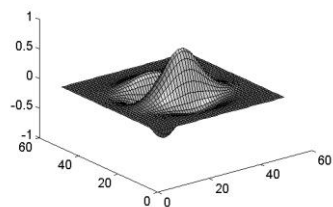
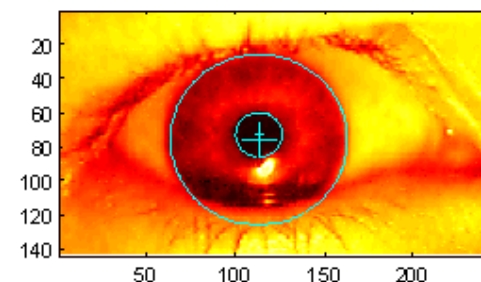
- 虹膜图案发育是“混乱的”
- 遗传影响很小或没有影响
- 即使是同卵双胞胎，也存在不相关的
- 特征在整个生命周期中保持稳定

虹膜识别：历史

- 1936年——由眼科医生Frank Burch提出虹膜纹理具有唯一性。
- 1980年代——詹姆斯·邦德电影提出眼睛识别身份设想。
- 1986年——第一项专利出现：虹膜识别专利。
- 1994年——约翰·道格曼提出虹膜识别算法。

虹膜扫描

- 扫描仪定位虹膜
- 拍摄黑白照片
- 使用极坐标.....
- 二维小波变换
- 获取 256 字节的虹膜代码



测量虹膜相似性

- 基于汉明距离 (有多少位不一样)
 - x: 识别阶段Alice的虹膜代码
 - y: 为Alice录入阶段存在数据库中的虹膜扫描结果。
- 定义 $d(x, y)$ 为:
 - 不匹配位数 / 比较位数
 - $d(0010, 0101) = 3/4$ 且 $d(101111, 101001) = 1/3$
- 计算2048位虹膜编码的 $d(x, y)$
 - 完全匹配为 $d(x, y) = 0$
 - 对于同一虹膜, 预期距离为0.08
 - 随机预期距离为0.50
 - 距离小于0.32, 则接受虹膜扫描结果为匹配。

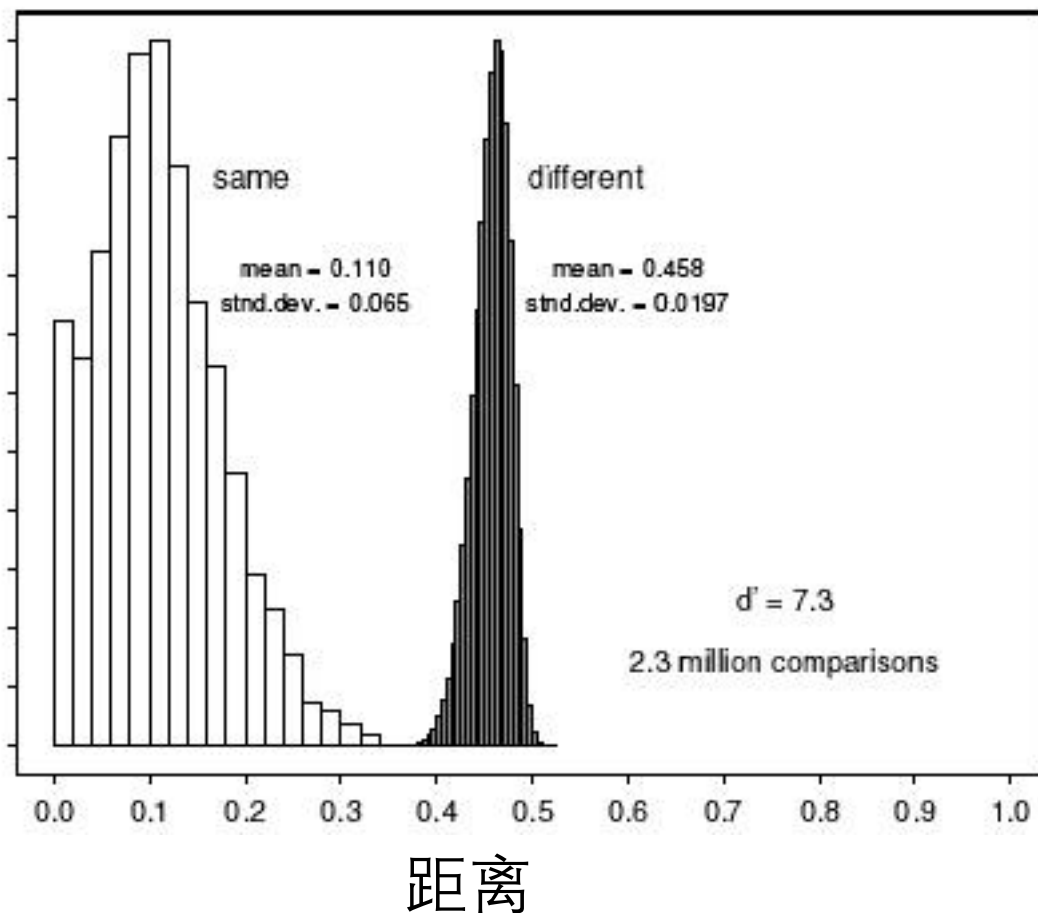
虹膜扫描错误率

距离 误判率

0.29	$1/1.3 * 10^{10}$
0.30	$1/1.5 * 10^9$
0.31	$1/1.8 * 10^8$
0.32	$1/2.6 * 10^7$
0.33	$1/4.0 * 10^6$
0.34	$1/6.9 * 10^5$
0.35	$1/1.3 * 10^5$



== 相等错误率



攻击虹膜扫描

- 清晰的眼睛**照片**
 - 攻击者可能使用眼睛的照片
- 通过对一张旧照片进行虹膜扫描，确认了这位阿富汗妇女的身份。
 - 故事全文请点击[此处查看](#)。
- 为了防止攻击，扫描仪可以使用光线来确认虹膜是否“正常”。

等错误率比较

- 等错误率 (EER): 误判率 == 拒判率
 - **指纹** 实际应用的生物识别技术的等错误率 (EER) 范围约为 10^{-3} 到高达 5%
 - **手掌** 的等错误率大概在 10^{-3}
- 理论上, **虹膜扫描** 的等错误率 (EER) 约为 10^{-6} 。
 - 注册阶段可能对准确性至关重要。
- 大多数生物识别技术都比指纹识别差得多!
- 生物识别技术可用于身份验证.....

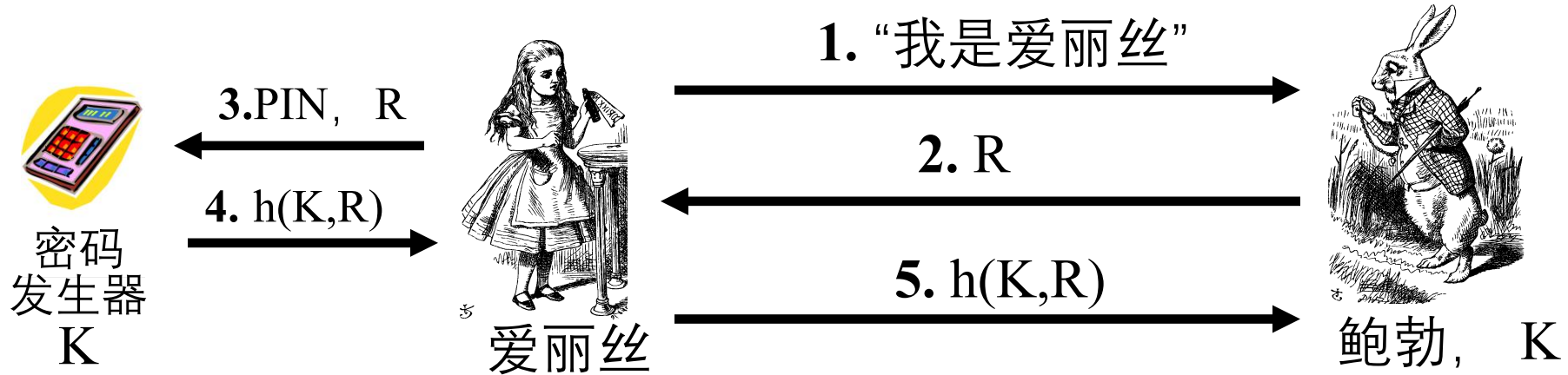
生物识别技术

- 生物识别信息很难伪造。
- 但攻击者可能
 - 偷走爱丽丝的拇指
 - 复印鲍勃的指纹、眼睛等。
 - 攻击软件、数据库、“可信路径”.....
- 如何撤销“泄露/破坏”的生物识别信息？ 不可撤销
- **生物识别技术并非万无一失**

你拥有的东西

- 你拥有的东西
- 例如以下情况.....
 - 车钥匙
 - 笔记本电脑（或MAC地址）
 - 密码生成器（下一步）
 - ATM卡、智能卡等。

密码生成器



- 鲍勃发来的“挑战” R 。
- 在密码生成器中输入PIN 码和 R 。
- 使用 R 对对称密钥 K 进行哈希运算
- Alice 发送“响应” $h(K, R)$ 回到鲍勃
- 鲍勃对响应进行验证
- 注：爱丽丝有 pwd生成器和知道 PIN码

双因素身份验证

- 需要满足以下三个条件中的任意两个：
 - 你知道的
 - 你拥有的东西
 - 你是谁
- 示例
 - ATM: 银行卡和密码
 - 信用卡: 卡片和签名
 - 密码生成器: 设备和 PIN 码
 - 智能卡: 卡和密码/PIN码

单点登录 (Single Sign-On, SSO)

- 反复输入密码很麻烦
 - 爱丽丝只想进行一次身份验证。
 - 无论爱丽丝走到哪里，“凭证”都会一直跟着她。
 - 后续的身份验证对Alice来说是透明的。
- Kerberos——单点登录协议
- 互联网单点登录？
 - 微软： **Passport**
 - 其他人： **Liberty Alliance**
 - 安全断言标记语言 (**SAML**)

网络 Cookie

- Cookie 由网站提供并存储在用户的计算机上。
- Cookie 会索引网站上的数据库。
- Cookie 会在会话之间**保持状态**
 - Web 使用无状态协议：HTTP
 - Cookie 还用于维护会话状态
- 有点像网站的单点登录。
 - 但是，这是一种非常非常弱的身份验证形式。
- Cookie 也会引发隐私问题

测试

- 1. 用户输入用户名 + 密码登录系统 属于哪一类?
- 2. 用户登录一次后, 可以访问多个网站 (无需再次输入密码) 属于哪一类?
- 3. 用户输入密码 + 手机验证码 属于哪一类?
- 4. 用户刷脸进入机场安检系统, 系统不知道他是谁, 只是在数据库中搜索匹配, 属于哪一类?
- 5. 用户输入指纹解锁手机, 属于哪一类?
- 6. 攻击者不断尝试所有可能密码直到成功, 属于哪一类攻击?
- 7. 攻击者使用常见密码列表 (如123456、password) 进行破解, 属于哪一类攻击?
- 8. 用户用 Google 账号登录第三方网站, 属于哪一类?
- 9. 进入机场, 我们需要证件信息和指纹特征来准许登机, 属于哪一类?
- 10. 在密码存储中, 采用哈希加盐的主要安全作用是什么?

访问与控制

- 身份验证
 - 身份验证——谁会去那里？
 - 密码——你知道的东西
 - 生物识别技术——你自身的一部分（你就是你的关键）
 - 你拥有的东西

Next Week

- 授权——您有权这样做吗？
 - 访问控制矩阵/访问控制列表/权限
 - MLS/多边安全
 - BLP/ Biba
 - 隐蔽渠道
 - 推理控制
 - 验证码
 - 防火墙
 - 入侵检测系统

Thank you.